C|PENT v2
Certified Penetration Testing Professional

# Certified Penetration Testing Professional

## theHarvester Cheat Sheet

### theHarvester

Source: *https://www.edge-security.com*

theHarvester is a simple, powerful, and effective tool used in the early stages of a penetration test or red team engagement. It is also used for open-source intelligence (OSINT) gathering to help determine a company's external threat landscape. It can gather emails, names, subdomains, IPs, and URLs using multiple public data sources.



### 1. theHarvester Options

| Syntax | |
|---|---|
| `theharvester options` | |
| **Options** | |
| `-d` | Domain to search or company name |
| `-b: data source` | Baidu, bing, bingapi, dogpile, google, googleCSE, googleplus, google-profiles, LinkedIn, pgp, twitter, vhost, yahoo, all |
| `-s` | Start in result number X (default: 0) |
| `-v` | Verify hostname via DNS resolution and search for virtual hosts |
| `-f` | Save the results into an HTML and XML file |

| | |
|---|---|
| `-n` | Perform a DNS reverse query on all ranges discovered |
| `-c` | Perform a DNS brute force for the domain name |
| `-t` | Perform a DNS TLD expansion discovery |
| `-e` | Use this DNS server |
| `-l` | Limit the number of results to work with (bing goes from 50 to 50 results, google 100 to 100) |
| `-h` | Use SHODAN database to query discovered hosts |

## 2. theHarvester Passive Data Source

| Data Source | Description |
|---|---|
| **baidu** | Baidu search engine - www.baidu.com |
| **bing** | Microsoft search engine - www.bing.com |
| **bingapi** | Microsoft search engine, through the API |
| **dnsdumpster** | DNSdumpster search engine - https://dnsdumpster.com/ |
| **dogpile** | Dogpile search engine - www.dogpile.com |
| **duckduckgo** | DuckDuckGo search engine - www.duckduckgo.com |
| **Exalead** | Meta search engine - www.exalead.com/search |
| **github-code** | GitHub code search engine (Requires a GitHub Personal Access Token, see below.) - www.github.com |
| **brave** | Brave search engine - https://search.brave.com/ |
| **bufferoverun** | Requires an API key - https://tls.bufferover.run |
| **crtsh** | Comodo Certificate search - https://crt.sh |
| **hunter** | Hunter search engine (Requires an API key, see below.) - www.hunter.io |
| **intelx** | Intelx search engine (Requires an API key, see below.) - www.intelx.io |
| **hackertarget** | Online vulnerability scanners and network intelligence to help organizations - https://hackertarget.com |

| | |
|---|---|
| `hunterhow` | Internet search engines for security researchers - https://hunter.how |
| `otx` | AlienVault Open Threat Exchange - otx.alienvault.com |
| `securityTrails` | Security Trails search engine, the world's largest repository of historical DNS data<br>- www.securitytrails.com |
| `shodan` | Shodan search engine will search for ports and banners from discovered hosts - www.shodanhq.com |
| `onyphe` | Cyber defense search engine - https://www.onyphe.io/ |
| `rapiddns` | DNS query tool which make querying subdomains or sites of a same IP easy! https://rapiddns.io |
| `sitedossier` | Find available information on a site - http://www.sitedossier.com |
| `tomba` | Tomba search engine - https://tomba.io |
| `urlscan` | Sandbox for the web that is a URL and website scanner - https://urlscan.io |
| `vhost` | Bing virtual hosts search |
| `virustotal` | virustotal.com domain search |
| `yahoo` | Yahoo search engine |
| `pgp` | PGP key server - pgp.rediris.es<br>Example: theharvester -d microsoft.com -b pgp |

## 3. theHarvester Active Data Source

| Data Source | Description |
|---|---|
| `DNS brute force` | Runs dictionary brute force enumeration |
| `DNS reverse lookup` | Reverse lookup of IP´s discovered to find hostnames |
| `DNS TDL expansion` | TLD dictionary brute force enumeration |

## 4. theHarvester Commands

| Command | Description |
|---|---|
| `theharvester -d microsoft.com -l 500 -b google` | Perform passive scanning on the target domain (Microsoft.com) by limiting the results to 500 (-l 500) using Google (-b) |
| `theharvester -d kali.org -l 500 -b google -f output.txt` | Perform passive scanning on the target domain (kali.org) by limiting the results to 500 (-l 500) using Google (-b) and saving the output to a text file (-f output.txt) |
| `theHarvester.py -d google.com -c -b google` | Perform active scanning and brute-forcing subdomains of the target domain (google.com) using option -c using Google (-b) |